

Collaborative Discussion 2: Peer Responses

Abinel Madzivire

Peer Response 1

Dear Kaona Hoxha

I agree with your observation that the principal weakness of CVSS lies not necessarily in the framework itself, but in the way its numerical scores can create an impression of objectivity and precision. Your reference to the inconsistency identified by Wunder *et al.* (2024) is particularly important because it demonstrates that different assessors, and even the same assessors over time, may interpret CVSS metrics differently. This potentially reduces confidence in using CVSS scores as the primary basis for remediation decisions.

I also support your argument for incorporating organisational context into vulnerability prioritisation. FIRST (2020) acknowledges that CVSS measures vulnerability severity rather than organisational risk. Consequently, relying solely on the Base Score may result in resources being directed towards technically severe vulnerabilities that pose relatively limited operational risk, while exploitable vulnerabilities affecting critical assets receive insufficient attention.

Your recommendation of SSVC provides a strong alternative because it links vulnerability characteristics to specific stakeholder actions. Spring *et al.* (2020) emphasise factors such as exploitation status, technical impact and mission relevance, enabling organisations to prioritise vulnerabilities according to their operational environment. However, rather than completely replacing CVSS, I would suggest integrating both approaches: CVSS can provide standardised technical

severity information, while SSVC can translate that information into context-sensitive remediation decisions.

References

FIRST (2020) *Common Vulnerability Scoring System v3.1: Specification Document*. Available at: <https://www.first.org/cvss/v3.1/specification-document> (Accessed: 19 September 2026).

Spring, J.M., Hatleback, E., Householder, A.D., Manion, A. and Shick, D. (2020) *Prioritizing Vulnerability Response: A Stakeholder-Specific Vulnerability Categorization (Version 1.1)*. Pittsburgh, PA: Carnegie Mellon University Software Engineering Institute.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) 'Shedding light on CVSS scoring inconsistencies: a user-centric study on evaluating widespread security vulnerabilities', in *2024 IEEE Symposium on Security and Privacy*. San Francisco, CA: IEEE, pp. 1102–1121.

Peer Response 2

Dear Janet Karani

I agree with your argument that the findings of Wunder *et al.* (2024) raise important concerns about the consistency and reliability of CVSS. The fact that assessors may interpret metrics such as Scope, User Interaction and Privileges Required differently demonstrates that apparently objective numerical scores can still be influenced by subjective judgement. This is particularly significant because inconsistent scoring may lead organisations to make different remediation decisions when faced with the same vulnerability.

Your distinction between vulnerability severity and organisational risk is also important. CVSS provides useful information about technical characteristics, but risk depends on additional factors such as asset criticality, threat activity and uncertainty. As Aven and Thekdi (2025) argue, effective risk assessment should consider context and uncertainty rather than depend solely on numerical values.

I also agree that EPSS offers an important advantage because it focuses on the likelihood of exploitation rather than technical severity alone. However, I would suggest that EPSS should complement rather than completely replace CVSS. CVSS can still provide valuable information about potential technical impact, while EPSS contributes evidence about exploitation probability. Combining both approaches with organisational context could therefore support more balanced vulnerability prioritisation and help security teams allocate limited remediation resources more effectively.

References

Aven, T. and Thekdi, S. (2025) *Risk Science*. 3rd edn. Abingdon: Routledge.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) 'Shedding light on CVSS scoring inconsistencies: a user-centric study on evaluating widespread security vulnerabilities', *2024 IEEE Symposium on Security and Privacy*, pp. 1102–1121.